

Segurança da Informação (S.I.)

Gestão de Vulnerabilidades

Prof. Me. Euclides Nasorri Gottsfritz
euclides.gottsfritz@ifsp.edu.br

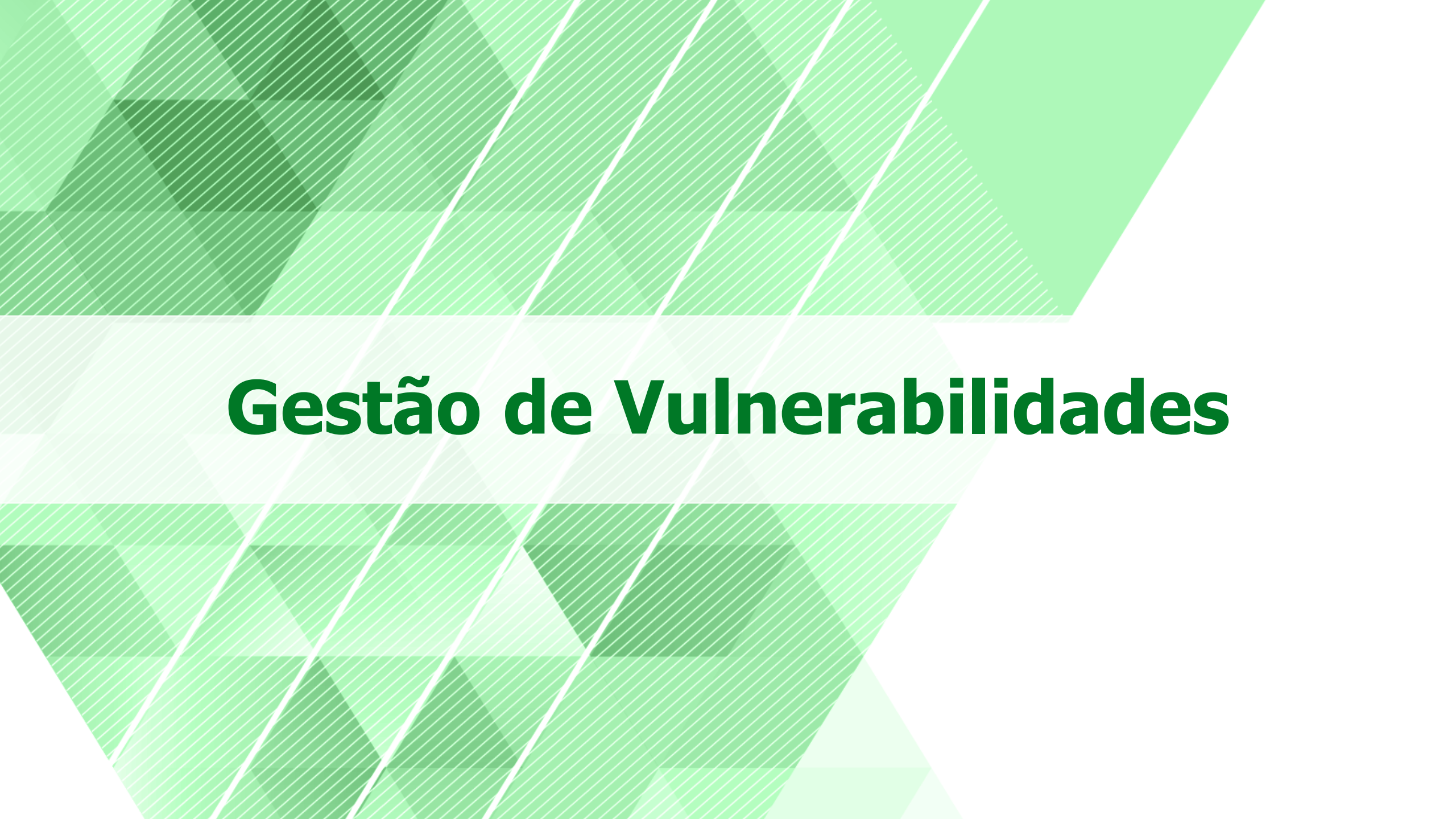


INSTITUTO FEDERAL
São Paulo
Campus Catanduva

Agenda



- Gestão de Vulnerabilidade;
 - CVE;
 - CWE;
 - OWASP;
- Considerações Finais



Gestão de Vulnerabilidades

Gestão de Vulnerabilidades

- Como vimos em aulas passadas, **Vulnerabilidade** é:
 - “**Fragilidade** de um ATIVO ou grupo de ATIVOS que pode ser **explorada** por uma ou mais **Ameaças**” (ISO 27002);
 - Em outras palavras, qualquer **fraqueza** que possa ser utilizada para **comprometer** a segurança de **sistemas** ou **informações**;



- Elas devem ser Identificadas e Corrigidas, e possuem várias Fontes;
 - Hoje iremos ver sobre **Vulnerabilidades de Software**.

Gestão de Vulnerabilidades

- As Vulnerabilidades de Software possuem **2 grandes grupos**:
 - **Conhecidas**: São divulgadas e conhecidas no meio computacional, **possuem gestão através de alertas e classificação**;
 - **Desconhecidas**: São vulnerabilidades ainda não divulgadas, **sem gestão e/ou alerta**.
- Uma das organizações mais utilizados como base na Gestão de Vulnerabilidades Conhecidas é o **MITRE**;



Gestão de Vulnerabilidades

- O **MITRE** foi fundado em 1958 como uma organização sem fins lucrativos, **financiada pela Força Aérea dos EUA**, para fazer a “ponte” entre a pesquisa acadêmica e a indústria;
- Um dos primeiros projetos foi o **SAGE** (Semi-Automatic Ground Environment / Ambiente Terrestre Semiautomático), um **componente de defesa aérea** utilizado na Guerra Fria;



Gestão de Vulnerabilidades

- Inicialmente sua função era **prestar consultoria para agências governamentais e civis**;
- Em Janeiro de **1999** o MITRE lançou seu primeiro trabalho a fim de catalogar as Vulnerabilidades de Software através de um **White Paper** intitulado “**Towards a Common Enumeration of Vulnerabilities**” / “Em Direção a uma Enumeração Comum de Vulnerabilidades”;

Towards a Common Enumeration of Vulnerabilities

David E. Mann, Steven M. Christey

The MITRE Corporation

202 Burlington Rd., Bedford MA 01730

January 8, 1999

Gestão de Vulnerabilidades

- A partir desse conceito, e dado o sucesso da publicação, o MITRE criou um **grupo de trabalho** para ampliar os estudos e criou o **primeiro CVE List** (Common Vulnerabilities and Exposures List / Lista de Vulnerabilidades e Exposições Comuns), com **321 vulnerabilidades** conhecidas publicamente;

YEAR	VULNERABILITIES	YEAR	VULNERABILITIES
1999	321	2012	5288
2000	1438	2013	5142
2001	1323	2014	7948
2002	1691	2015	6494
2003	1223	2016	6457
2004	1612	2017	14645
2005	6708	2018	16512
2006	6885	2019	17308
2007	7322	2020	18375
2008	5673	2021	20161
2009	5732	2022	25059
2010	4639	2023	28961
2011	4150		

Gestão de Vulnerabilidades

- Em 2006, com a necessidade de uma “organização” mais detalhada e hierarquizada, foi publicado o PLOVER (Preliminary List Of Vulnerability Examples for Researchers / Lista Preliminar de Exemplos de Vulnerabilidade para Pesquisadores);
 - Esse documento lista mais de 1500 vulnerabilidades reais identificadas pelo seu nome CVE;
 - Porém, elas foram organizadas dentro de uma estrutura conceitual e detalhada com base no tipo de fraqueza, comportamento, falhas e defeitos de software;

PLOVER - Preliminary List Of Vulnerability Examples for Researchers

[*] Author: Steve Christey (coley@mitre.org)

[*] Date: March 15, 2006

[*] Document Version: 0.24

Disclaimer: This is a DRAFT document that does not represent an official position of The MITRE Corporation. This document has been created to spur progress in vulnerability classification and vulnerability research.

Gestão de Vulnerabilidades

- O PLOVER foi o primeiro esforço de abstrair, agrupar e classificar as fraquezas comuns das vulnerabilidades;
- Com base nas sugestões do PLOVER, em 2006 foi lançada a primeira lista CWE (Common Weakness Enumeration / Enumeração de Fraquezas Comuns);

Different types of security vulnerabilities



Unpatched software



Misconfiguration



Weak credentials



Easy-to-phish users



Trust relationship



Compromised credentials



Malicious insider



Missing/Poor Encryption

Gestão de Vulnerabilidades

- **Em resumo:**
 - O **CVE** é um sistema padronizado para **identificar e rastrear vulnerabilidades conhecidas** publicamente. Cada CVE tem um ID único e sintaxe padronizada. Ele fornece uma descrição detalhada da vulnerabilidade e pode fornecer informações sobre como corrigi-la;
 - O **CWE** é uma lista de **fraquezas comuns** de segurança em software e hardware, que são **divididas em uma hierarquia de níveis e categorias**. O CWE auxilia na identificação e categorização das fraquezas subjacentes que podem ser exploradas, o que ajuda no desenvolvimento seguro de software.



The background features a complex geometric pattern of overlapping hexagons in various shades of green. Diagonal white lines intersect these hexagons, creating a sense of depth and movement. The overall aesthetic is modern and tech-oriented.

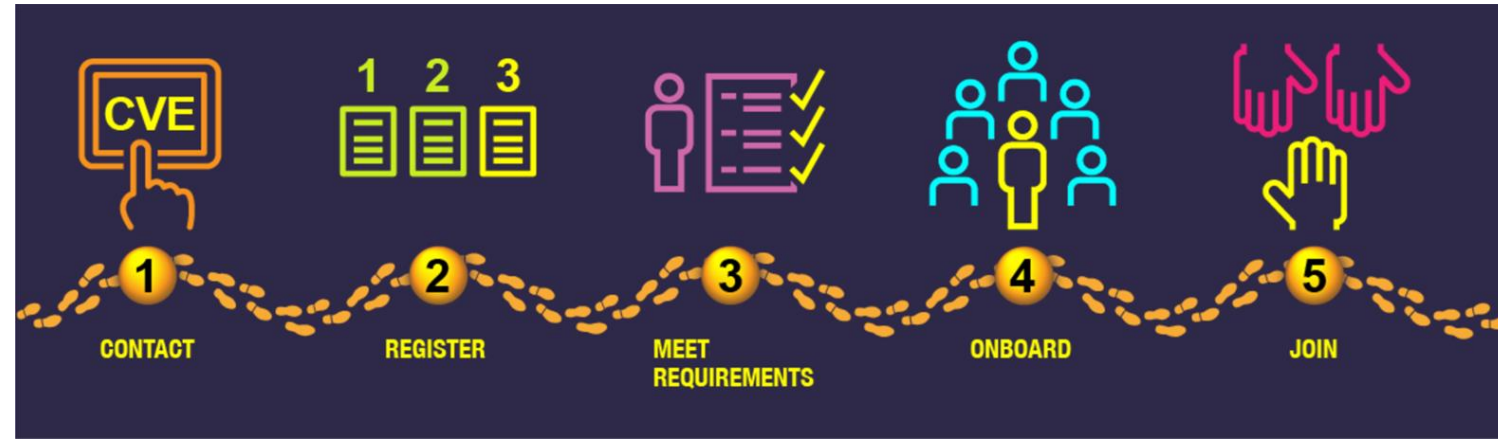
CVE



- A missão do Programa CVE é identificar, definir e catalogar vulnerabilidades de segurança cibernética divulgadas publicamente.
- Há um Registro CVE para cada vulnerabilidade no catálogo.
- As vulnerabilidades são descobertas, então atribuídas e publicadas por organizações de todo o mundo que fizeram parceria com o Programa CVE, as CNAs;
- **Fonte:** <https://www.cve.org/About/Overview>

CVE

- Os parceiros publicam Registros CVE para comunicar descrições consistentes de vulnerabilidades.



- Esses Registros são usados por Profissionais de Tecnologia da Informação e Segurança Cibernética para **garantir que estejam discutindo o mesmo problema** e para coordenar seus esforços para **priorizar e abordar as vulnerabilidades**.
- Fonte:** <https://www.cve.org/About/Overview>

CVE

Search

[CVE List Search Tips](#) | [Provide Feedback](#)

CVE™ Program Mission

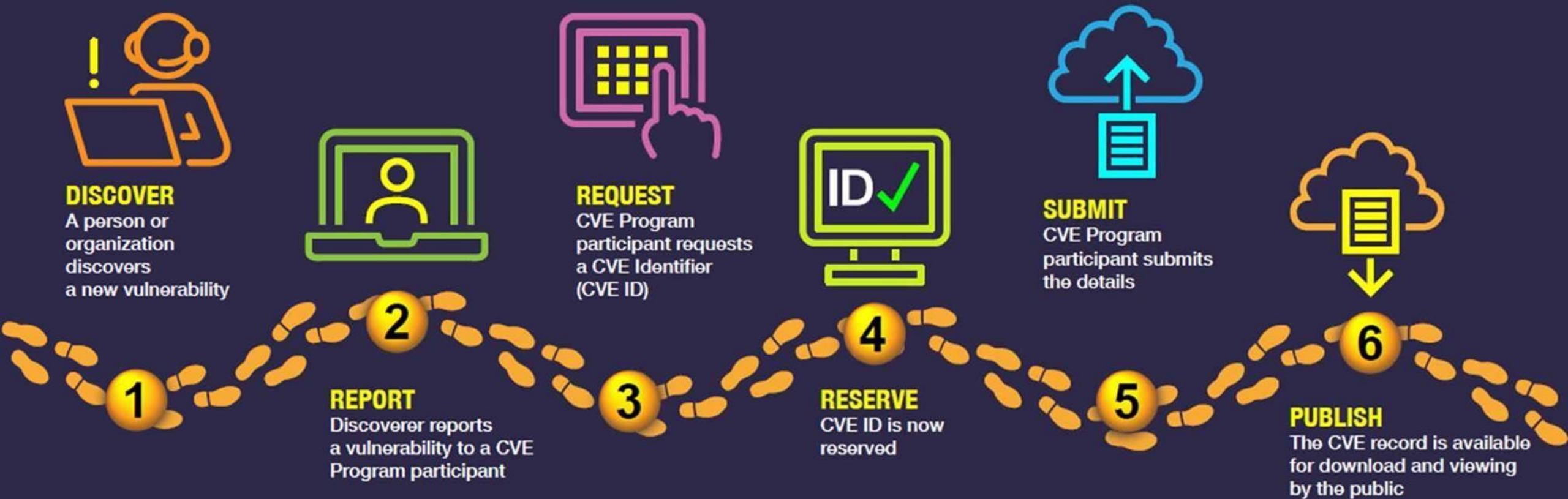
Identify, define, and catalog publicly disclosed cybersecurity vulnerabilities.

There are currently over **363,000** CVE Records accessible via [Download](#) or **Keyword Search** above.

Quantidade de registros até o momento

CVE – Ciclo de Vida

1 – Descobrir 2 – Reportar 3 – Requisitar 4 – Reservar 5 – Submeter 6 - Publicar



CVE-2020-10987

Required CVE Record Information

CNA: MITRE Corporation

Published: 2020-07-13 **Updated:** 2020-07-13

Description

The goform/setUsbUnload endpoint of Tenda AC15 AC1900 version 15.03.05.19 allows remote attackers to execute arbitrary system commands via the deviceName POST parameter.

Product Status

[Learn more](#)

Information not provided

References

- <https://www.ise.io/research/> 
- <https://blog.securityevaluators.com/tenda-ac1900-vulnerabilities-discovered-and-exploited-e8e26aa0bc68> 

CVE Program

Updated: 2024-08-04

This container includes required additional information provided by the CVE Program for this vulnerability.

References

- <https://www.ise.io/research/>  x_transferred
- <https://blog.securityevaluators.com/tenda-ac1900-vulnerabilities-discovered-and-exploited-e8e26aa0bc68>  x_transferred

CVE

Discovered and Exploited

Demonstrating how remote attackers can gain control of the Tenda AC15 AC1900.



Sanjana Sarda · [Follow](#)

Published in Independent Security Evaluators · 7 min read · Jul 10, 2020



199



1



Fonte: <https://blog.securityevaluators.com/tenda-ac1900-vulnerabilities-discovered-and-exploited-e8e26aa0bc68>



CWE



- A CWE é uma **lista** desenvolvida pela comunidade **sobre fraquezas comuns de software e hardware**. Uma “fraqueza” é uma condição em um software, firmware, hardware ou componente de serviço que, sob certas circunstâncias, pode contribuir para a introdução de vulnerabilidades. **A Lista CWE associa o identificador de classificação que descrevem fraquezas em termos de CWEs.**
- **Fonte:** <https://cwe.mitre.org/about/index.html>

CWE

- Conhecer as fraquezas que resultam em vulnerabilidades significa que desenvolvedores de software, designers de hardware e arquitetos de segurança podem eliminá-las antes da implantação, quando é muito mais fácil e barato de fazê-lo.
- **Fonte:** <https://cwe.mitre.org/about/index.html>



CWE

- A parte mais interessante das CWE são os mapeamentos que ela realiza e disponibiliza para a comunidade;
- O CWE Top 25 é a lista das 25 fraquezas de software mais perigosas (prevalência e Impacto) em 2025, por exemplo;

CWE Top 25 (2025)
2025 Most Important Hardware Weaknesses
OWASP Top Ten RC1 (2025)
Seven Pernicious Kingdoms
Software Fault Pattern Clusters
SEI CERT Oracle Coding Standard for Java
SEI CERT C Coding Standard
SEI CERT Perl Coding Standard
Addressed by ISA/IEC 62443 Requirements
CISQ Quality Measures (2020)
CISQ Data Protection Measures
SEI ETF Security Vulnerabilities in ICS
Architectural Concepts

1435 - Weaknesses in the 2025 CWE Top 25 Most Dangerous Software Weaknesses

- .  Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') - (79)
- .  Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') - (89)
- .  Cross-Site Request Forgery (CSRF) - (352)
- .  Missing Authorization - (862)
- .  Out-of-bounds Write - (787)
- .  Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') - (22)
- .  Use After Free - (416)
- .  Out-of-bounds Read - (125)
- .  Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') - (78)
- .  Improper Control of Generation of Code ('Code Injection') - (94)
- .  Buffer Copy without Checking Size of Input ('Classic Buffer Overflow') - (120)
- .  Unrestricted Upload of File with Dangerous Type - (434)
- .  NULL Pointer Dereference - (476)
- .  Stack-based Buffer Overflow - (121)
- .  Deserialization of Untrusted Data - (502)
- .  Heap-based Buffer Overflow - (122)
- .  Incorrect Authorization - (863)
- .  Improper Input Validation - (20)
- .  Improper Access Control - (284)
- .  Exposure of Sensitive Information to an Unauthorized Actor - (200)
- .  Missing Authentication for Critical Function - (306)
- .  Server-Side Request Forgery (SSRF) - (918)
- .  Improper Neutralization of Special Elements used in a Command ('Command Injection') - (77)
- .  Authorization Bypass Through User-Controlled Key - (639)
- .  Allocation of Resources Without Limits or Throttling - (770)

CWE-89: Neutralização inadequada de elementos especiais usados em um comando SQL ('Injeção de SQL')

ID da Fraqueza: 89

Mapeamento de Vulnerabilidades : PERMITIDO

Abstração: Base

Veja informações personalizadas:

Conceptual

Operacional

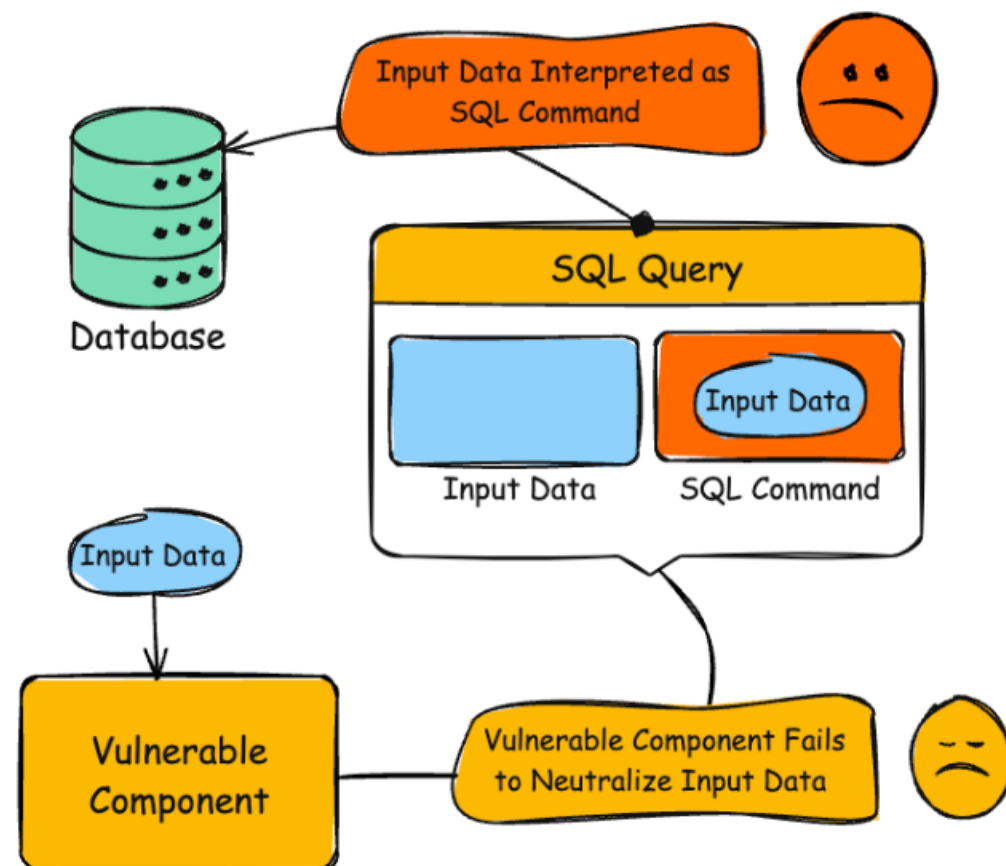
Mapeamento
amigável

Completo

Personalizado

▼ Descrição

O produto constrói todo ou parte de um comando SQL usando entradas influenciadas externamente por um componente a montante, mas não neutraliza, ou neutraliza incorretamente, elementos especiais que poderiam modificar o comando SQL pretendido quando este é enviado a um componente a jusante. Sem a remoção ou o uso de aspas suficientes da sintaxe SQL em entradas controláveis pelo usuário, a consulta SQL gerada pode fazer com que essas entradas sejam interpretadas como SQL em vez de dados comuns do usuário.



Fonte: <https://cwe.mitre.org/data/definitions/89.html>



- **CVE** -> **Vulnerabilidade** -> Identifica o “CASO”;
- **CWE** -> dá o tipo de **Fraqueza** que originou o “CASO”;
- Relação N para N;
 - **1 CVE** (Vulnerabilidade) pode ter **N CWEs** (Fraquezas);
 - **1 CWE** (Fraqueza) pode dar origem a **N CVEs** (Vulnerabilidade).
- Ao corrigir uma CVE, solucionamos a CWE?

NÃO



OWASP

OWASP



OWASP

Open Web Application
Security Project

- Adicionalmente ao MITRE, tem-se a **OWASP** (Open Worldwide Application Security Project / Projeto de Segurança de Aplicativos Abertos no Mundo);
- A OWASP Foundation foi lançada em 1º de dezembro de 2001, tornando-se uma **instituição de caridade sem fins lucrativos** nos Estados Unidos em 21 de abril de 2004;

OWASP

- Seu foco é o trabalho para melhoria da segurança de software de forma abrangente;
- Apoiam projetos de softwares abertos e seguros, desenvolvem comunidades em todo o mundo, além de fornecerem recursos educacionais.



OWASP

- “Somos uma **comunidade aberta** dedicada a permitir que organizações **concebam, desenvolvam, adquiram, operem e mantenham aplicativos confiáveis**. Todos os nossos projetos, ferramentas, documentos, fóruns e capítulos são **gratuitos e abertos** a qualquer pessoa interessada em melhorar a segurança de aplicativos.” (OWASP 2024).

- **Fonte:** <https://owasp.org/about/>



OWASP

- A OWASP possui um projeto chamado de “OWASP Top 10”;
- Esse projeto é um documento de conscientização voltados para desenvolvedores e segurança de aplicativos WEB;
- Ele apresenta 10 categorias de riscos de segurança considerados entre os mais críticos para aplicações Web;



- **Fonte:** <https://owasp.org/www-project-top-ten/>

OWASP

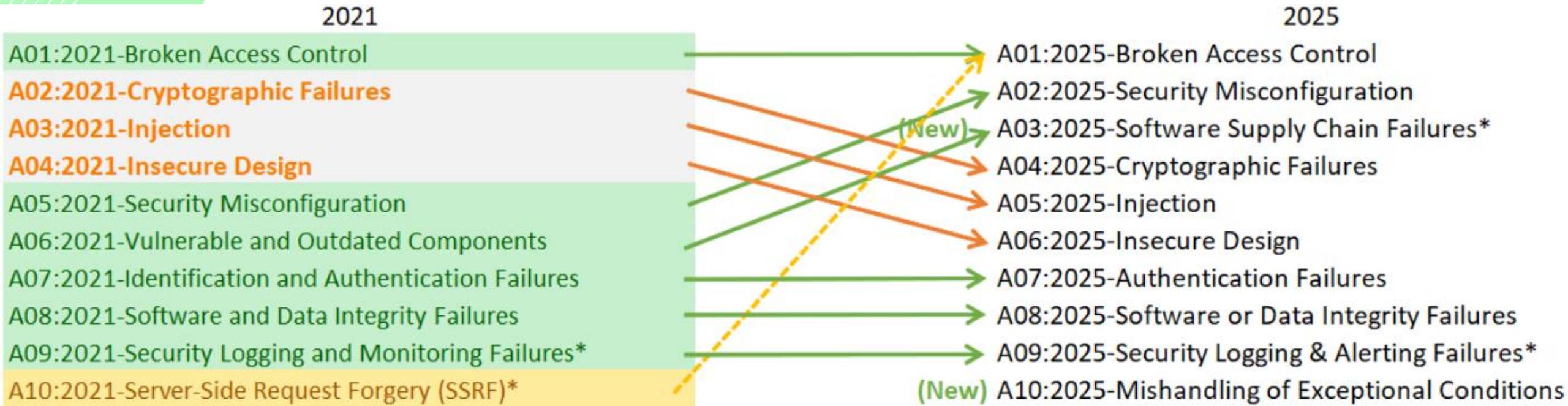
- Nas palavras da OWASP (2024):
 - “As empresas devem **adotar este documento** e iniciar o processo de **garantir** que seus aplicativos da web **minimizem esses riscos**. Usar o OWASP Top 10 é talvez o **primeiro passo** mais eficaz para **mudar a cultura de desenvolvimento de software** dentro da organização para que produza código mais **seguro**.”



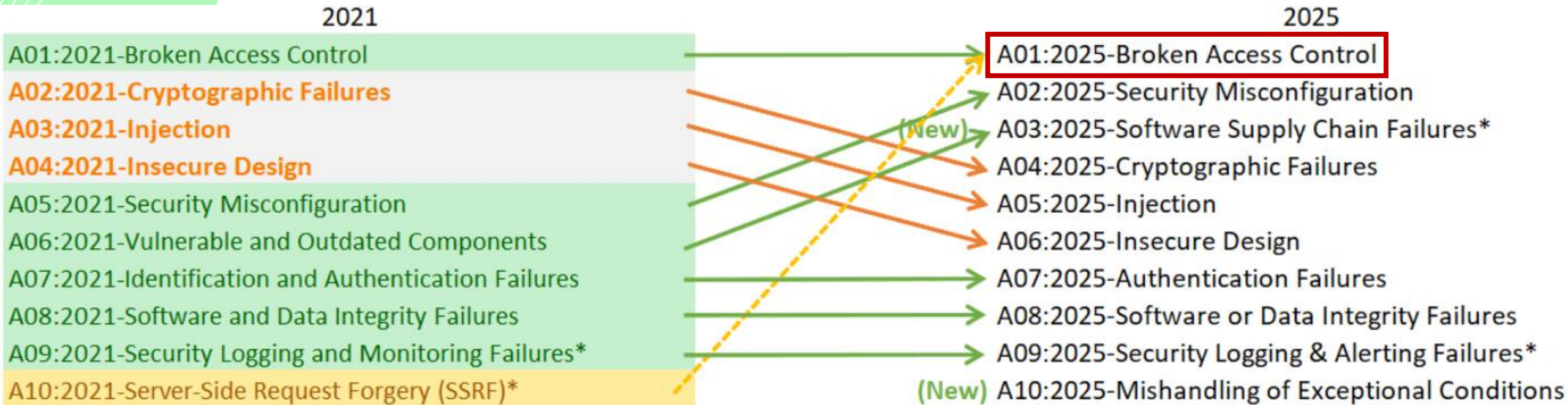
OWASP

- A **coleta de dados** feita pela OWASP é através de **Contribuições Voluntárias**, das mais variadas fontes;
 - Consultoria e fornecedores de soluções de segurança, sistemas de recompensas por encontrar Bugs, empresas e organizações que possuem controle de segurança de sistemas, etc.
- Esses dados são posteriormente **normalizados** para **comparações e classificações**;
- Também é recomendado que a **contribuição** seja feita de forma **conhecida**, o que **auxilia na confiabilidade** das informações.

OWASP



OWASP



- **A01:2025: Quebra de Controle de Acesso:**

- **100%** dos aplicativos testados apresentaram alguma forma de **Quebra de Controle de Acesso**.
Essa classificação possui 40 CWEs e foi a categoria com mais ocorrência que as outras.

OWASP

- **A01:2025 – Quebra de Controle de Acesso**

Mapeamento de CWEs	Taxa de incidência máxima	Taxa média de incidência	Cobertura máxima	Cobertura média	Exploração média ponderada	Impacto médio ponderado	Total de ocorrências	Total de CVEs
40	20,15%	3,74%	100,00%	42,93%	7.04	3,84	1.839.701	32.654

- E da **alguns tópicos** como:
 - Visão Geral, Descrição, Como Prevenir, Exemplos, Referências e CWEs Mapeados
- **Fonte:** https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/



Considerações Finais



Considerações Finais



- Nesta aula vimos sobre **Gestão de Vulnerabilidades**, e que existem algumas **organizações responsáveis** por mapear, catalogar e classifica-las;
- O **MITRE** é um deles, possui **papel histórico e operacional** nos programas **CVE e CWE**;
 - Foi o criador do **CVE List** (Lista de Vulnerabilidades e Exposições Comuns) que **cataloga TODAS as vulnerabilidades conhecidas e publicamente divulgadas**;
 - E que posteriormente, foi necessário criar um meio para classifica-las. Então o MITRE criou a **CWE List** (Lista de Enumeração de Fraquezas Comuns) que **Lista e Classifica fraquezas em comum** através de uma hierarquia de níveis e categorias.



Considerações Finais

- E por fim, estudamos a **OWASP**;
 - Uma instituição sem fins lucrativos com foco na **melhoria da segurança de software**;
 - Disponibiliza material de apoio gratuito, além de fóruns de discussão.
- Possui o projeto **OWASP Top 10** que é um **documento de conscientização** voltado para **desenvolvedores e segurança de aplicativos WEB**;
 - Ele apresenta as **10 categorias de riscos de segurança** em aplicativos Web;
 - Cada categoria é descrita de forma **detalhada**, sugestões de como **mitigar**, além de **exemplo e literatura complementar** através dos CWEs.



Referências



- MITRE Corporation. **CVE** – Common Vulnerabilities and Exposures. Disponível em: <https://www.cve.org/>
- MITRE Corporation. **CWE** – Common Weakness Enumeration. Disponível em: <https://cwe.mitre.org/>
- OWASP Foundation. **OWASP**. Disponível em: <https://owasp.org/>
- SÊMOLA, M. **Gestão da Segurança da Informação**: uma visão Executiva. Rio de Janeiro: 2. ed. Campus, 2014.

